ANCHOR CBS · INSA CYBERSECURITY AUDIT

Document: VULNERABILITY_REPORT.md · Generated 11 November 2026

Cybersecurity Vulnerability Assessment Report

System: CBS General — Web-Based SACCO Core Banking / ERP Back Office
Document ID: CBS-SEC-VR-2026-001
Version: 1.0
Assessment date: 10–11 November 2026
Code baseline: commit `2b23823 (security hardening) + working tree` (branch `hayder-update-FRA`)
Classification: Internal / Confidential
Companion documents: `security/COMPLIANCE_MATRIX.md`, `security/SRS.md`, `security/README.md`

1. Executive Summary

The assessment covered the SACCO core banking / ERP web platform, its REST API, PostgreSQL schema, authentication and authorization controls, audit trail, SMS/OTP integration, and front-end dependency posture.

Nine security findings are fixed, five are partially remediated, and five remain open. The most severe fixed finding was a legacy authentication design that issued a session for a username or role without verifying a password (Critical). The remediation introduced BCrypt password verification, generic `401` responses, server-side RBAC, account lockout, SMS-based MFA for privileged roles, security headers, a CORS allowlist, environment-based secrets, immutable audit logging, and dependency cleanup. A second hardening batch on 11 November 2026 added fine-grained POST authorization, production credential guards, and an append-only trigger on the legacy `audit_log`.

The highest residual risks are:

- Default demo credentials are now **production-guarded**, but explicit demo mode still uses `demo123` and a deployment that leaves `PRODUCTION=false` or a weak `SEED_PASSWORD` remains exposed (V-15, **Critical, Partial**). Existing databases with old `demo123` hashes also need rotation.
- Authorization is improved for sensitive POST endpoints, but PUT/PATCH, SMS, and some accounting writes remain broad; there are still no method-level `@PreAuthorize` checks (V-16, High, Partial).
- A TLS 1.3 nginx template exists, but it is **not deployed** on the audited host; mTLS is still absent (V-10, High, Partial).
- Encryption at rest and field-level encryption for Fayda ID/phone are not implemented (V-11, Medium, Open).

Residual risk is **Critical until the production guard is verified in the target deployment and old demo hashes are rotated**, then **High while V-16 and V-10 remain partial**, then **Medium** while encryption/pen-test/certification gaps remain. **One Critical finding remains partially open (V-15).**

Finding totals

Status	Critical	High	Medium	Low	Total
Fixed	1	4	4	0	**9**
Partial	1	3	0	1	**5**
Open	0	0	4	1	**5**
Total	**2**	**7**	**8**	**2**	**19**

> CVSS scores are **estimates** derived from CVSS v3.1 vectors using code review and request-level testing. They are not scanner output and do not include organization-specific environmental weighting.

1.1 Remediation update — 11 November 2026

Finding	Before	After	Evidence
V-16 — Coarse authorization	Open	**Partial**	Fine-grained POST rules in `SecurityConfig`; live teller `POST /api/gl-rules` → `403`, teller `POST /api/compliance/policy` → `403`, accountant `POST /api/gl-rules` → `400` (allowed validation), teller `POST /api/savings/transactions` → `400` (allowed). PUT/PATCH, `/api/sms/**`, and some accounting writes remain broad.
V-15 — Demo credentials	Open	**Partial**	`SEED_PASSWORD` env; `SecurityBootstrapCheck` fails startup when `PRODUCTION=true` and seed password is `demo123` or JWT is the demo default; `Login.tsx` falls back to `demo123` only in mock/dev mode. Local `.env` remains `PRODUCTION=false` / `demo123`; demo mode still works.
V-19 — Mutable `audit_log`	Open	**Fixed**	`V29__audit_log_immutable.sql` adds `audit_log_append_only`; live `UPDATE` / `DELETE` rejected with the append-only error; `INSERT` still works.
V-10 — TLS/mTLS	Open	**Partial**	`deploy/nginx-cbs.conf.template` enforces TLS 1.3, HSTS, security headers, and HTTP→HTTPS; not deployed on the audited host; no mTLS.
V-07 — Vulnerable dependencies	Fixed	**Fixed**	Before: 3 high (`@ant-design/pro-components`, `@ant-design/pro-layout`, `path-to-regexp`). After removing ProComponents/ProLayout and replacing 40 `ProCard` usages with `.page-shell`: `npm audit --omit=dev` → 0.
V-09 — MFA operational lifecycle	Fixed (capability)	**Partial**	SMS OTP for ADMIN/MANAGER remains implemented and tested (`202` manager, `200` teller), but `REQUIRE_MFA` defaults to false, only two roles are covered, and enrolment/reset/recovery are manual (V-14).
V-06 — Hardcoded secrets	Fixed	**Fixed**	Environment-driven secrets plus `SecurityBootstrapCheck` production guard; `backend/.env` is gitignored and not tracked.

Evidence source for this update: `security/evidence/security-test-results.md` and a re-check of the running local instance (teller/accountant role requests, `audit_log` trigger, `npm audit`).

> V-09 was reclassified from Fixed to Partial after the operational review: the SMS MFA capability works, but default-off configuration and manual enrolment/recovery mean it is not fully operationalized. The lifecycle gap is also tracked as V-14.

---

2. Scope and Boundaries

In scope

- Spring Boot backend (`backend/src/main/java/com/cbs/sacco/**`), 25 functional packages.
- REST API under `/api/**`, including authentication, RBAC, validation, error handling, audit, and SMS/OTP endpoints.
- PostgreSQL schema and migrations (`backend/src/main/resources/db/migration/V1` – `V29`).
- React/TypeScript front end (`src/**`), session handling, and the production dependency tree.
- Configuration (`application.yml`, `.env.example`, `.gitignore`).
- Local running instance used for authenticated and unauthenticated API tests.

Out of scope / not evidenced

- POS terminals, electronic invoice machines, payment-card readers, firmware, secure boot, TPM, JTAG/UART, OTA updates, fiscal printers, and device enclosures. **The platform contains none of these.**
- TLS termination, reverse-proxy configuration, firewall rules, WAF, and certificate lifecycle (deployment-managed; no infrastructure access).
- Volume/disk encryption, database TDE, backup encryption, and key-management systems.
- Host OS hardening, container configuration, and cloud/provider controls.
- Independent penetration testing, social engineering, and physical security.
- ISO/IEC 27001, ISO/IEC 15408, PCI-DSS, and local fiscal-authority certification.

Business context

The system is a back-office SACCO platform for member management, savings, term deposits, shares, loans, accounting, cash operations, payments, approvals, day control, compliance monitoring, reporting, SMS notifications, and audit. It does not process or store card data, and it does not issue fiscal invoices.

---

3. Methodology

Activity	Detail
Static code review	Authentication, JWT filter, security configuration, CORS, audit trail, SMS service, financial services, controllers, migrations, and front-end auth context.
Configuration review	Secret handling, JWT lifetime, MFA flag, HTTPS flag, CORS origins, error handling, security headers.
Dynamic API testing	`curl` requests against `http://localhost:8080` with unauthenticated, TELLER, AUDITOR, MANAGER, and ADMIN contexts. Non-destructive payloads only.
Database inspection	Read-only checks of `audit_trail` and `sms_log` triggers; audit hash-chain verification through the API.
Dependency scan	`npm audit --omit=dev`; package-tree inspection for removed ProComponents/ProLayout packages.
Evidence quality	Every finding cites a file path, endpoint, or observed HTTP response. No scanner output or third-party report is claimed.

Testing constraints. The lockout and MFA tests were not repeated during final verification to avoid locking accounts and sending live SMS. Their results are recorded from the authenticated audit run. Tests were performed over HTTP on a development instance; HSTS was verified by sending `X-Forwarded-Proto: https`, which the application honours through `server.forward-headers-strategy: framework`.

Test-harness caveat. The pre-existing integration tests (`BaseApiIT`, `SaccoApiIntegrationTest`, `ApiContractIT`, `PerformanceIT`, `EdgeCasesIT`, and others) and `scripts/api-smoke.sh` still send the legacy passwordless login payload. They are **not** valid release evidence for the remediated authentication contract and must be updated. This is tracked as O-01.

---

4. Severity Ratings

CVSS v3.1 base metrics are used as a common language. Ratings are adjusted only for exploitation preconditions that are evident from the architecture (for example, "requires an authenticated low-privilege account").

Rating	CVSS range	Interpretation
Critical	9.0–10.0	Unauthenticated compromise of confidentiality/integrity or full administrative takeover.
High	7.0–8.9	Serious compromise, privilege escalation, or exposure of sensitive data.
Medium	4.0–6.9	Requires specific conditions or has limited blast radius.
Low	0.1–3.9	Defense-in-depth, process, or limited-information issue.

Process/certification gaps that are not directly exploitable are labelled **Low / Informational** with score `–`.

---

5. Findings Summary

ID	Finding	Severity	CVSS	Status	Component
V-01	Role-only login issued tokens without password verification	Critical	9.8	**Fixed**	`AuthService`, `AuthController`, login UI
V-02	`/api/auth/users` exposed the user directory without authentication	High	7.5	**Fixed**	`SecurityConfig`
V-03	No server-side RBAC; any authenticated token could reach all APIs	High	8.1	**Fixed**	`SecurityConfig`
V-04	No account lockout after repeated failed logins	Medium	5.3	**Fixed**	`AuthService`, `app_user`
V-05	Missing security headers and permissive CORS risk	Medium	5.4	**Fixed**	`SecurityConfig`
V-06	Hardcoded JWT/DB secrets and insecure defaults	High	7.5	**Fixed**	`application.yml`, `.env.example`

ID	Finding	Severity	CVSS	Status	Component
V-07	Vulnerable front-end dependencies	High	7.3	**Fixed**	`package.json`, lockfile
V-08	Mutable audit log with no tamper evidence	Medium	6.5	**Fixed**	`audit_trail`, Hibernate listener, triggers
V-09	MFA implemented but not fully operationalized	High	8.1	**Partial**	`AuthService`, `SmsService`, `SecurityBootstrapCheck`
V-10	TLS 1.3 not enforced; mTLS not implemented	High	7.4	**Partial**	`SecurityConfig`, `deploy/nginx-cbs.conf.template`
V-11	No verified encryption at rest; Fayda ID/phone stored plaintext	Medium	6.1	**Open**	PostgreSQL schema, infrastructure
V-12	No independent penetration test or full OWASP scan	Medium	—	**Open**	Assurance process
V-13	No ISO 27001 / ISO 15408 / PCI-DSS certification evidence	Low	—	**Open**	Compliance programme
V-14	2FA enrolment, reset, and recovery lifecycle incomplete	Low	3.1	**Partial**	`AuthService`, `SmsService`, UI
V-15	Default demo credentials remain in demo mode; production guard added	**Critical**	9.8	**Partial**	`DataSeeder`, `SecurityBootstrapCheck`, `src/pages/Login.tsx`
V-16	Coarse authorization; no method-level role checks	High	7.1	**Partial**	`SecurityConfig`, controllers
V-17	Systematic input validation incomplete; 107 map-based request bodies	Medium	5.3	**Open**	Controllers, DTO layer
V-18	JWT stored in browser `localStorage`	Medium	5.4	**Open**	`src/context/AuthContext.tsx`
V-19	Legacy `audit_log` mutability (now append-only)	Medium	4.9	**Fixed**	`audit_log`, `V29__audit_log_immutable.sql`

6. Detailed Findings

6.1 Remediated and Fixed Findings

V-01 — Role-only login issued tokens without password verification

- **Severity:** Critical (CVSS 9.8, `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`)
- **Affected:** `backend/src/main/java/com/cbs/sacco/auth/service/AuthService.java`, `AuthController.java`, `src/context/AuthContext.tsx`
- **Description:** The legacy login flow resolved a user from a username or role and issued a JWT without comparing a password. Any caller who knew a username or role string could obtain a valid session, including an ADMIN session.
- **Evidence:** The legacy contract is still visible in `scripts/api-smoke.sh` (token acquisition with `{"username":"admin"}`), `AuthContext.switchRole` (`POST /api/auth/login` with `{role}` only), and the integration-test helpers (`BaseApiIT.loginToken`, `loginTokenByRole`; `PerformanceIT.login`; `SaccoApiIntegrationTest.roleLoginResolvesDemoUser`).
- **Impact:** Full account takeover and administrative compromise without credentials. This invalidated every downstream role control.
- **Remediation applied:** `AuthService.login` now requires a non-blank password and `passwordEncoder.matches(...)` against the BCrypt hash. Failure returns a generic `401 Invalid username or password`; the `role` field is no longer an authentication factor. The front end sends the password.
- **Verification:** Login without a password → `401`; wrong password → `401`; correct password → `200` with JWT.
- **Residual:** `src/pages/Login.tsx` still defaults a blank password to `demo123` (see V-15), and the legacy test harness must be updated (O-01).

V-02 — `/api/auth/users` exposed the user directory without authentication

- **Severity:** High (CVSS 7.5, `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`)
- **Affected:** `backend/src/main/java/com/cbs/sacco/config/SecurityConfig.java`

- **Description:** User listing and creation were reachable without an authenticated ADMIN context. The endpoint returned usernames, full names, titles, branches, and roles, enabling targeted attacks and user enumeration.
- **Remediation applied:** `/api/auth/users/**` is restricted to `hasRole("ADMIN")` before the general method rules.
- **Verification:** TELLER `403`, MANAGER `403`, ADMIN `200`; unauthenticated `401`.

V-03 — No server-side RBAC; any authenticated token could reach all APIs

- **Severity:** High (CVSS 8.1, `AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`)
- **Affected:** `backend/src/main/java/com/cbs/sacco/config/SecurityConfig.java`
- **Description:** Authorization relied on the presence of a valid token. A TELLER or AUDITOR token could invoke administrative or write operations.
- **Remediation applied:** Explicit request matchers enforce ADMIN-only user/system/admin areas, audit read for ADMIN/MANAGER/AUDITOR, no POST/PUT/PATCH for AUDITOR, and DELETE only for ADMIN. Authentication entry point returns JSON `401`; access-denied handler returns JSON `403`.
- **Verification:** TELLER and MANAGER `403` on `/api/auth/users`; ADMIN `200`; AUDITOR `403` on POST and DELETE; unauthenticated `401`; TELLER `200` on `/api/members`.
- **Residual:** The rules are HTTP-method/path-prefix based, not per-endpoint (see V-16).

V-04 — No account lockout after repeated failed logins

- **Severity:** Medium (CVSS 5.3, `AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`)
- **Affected:** `AuthService.java`, `app_user` table
- **Description:** Unlimited password guessing was possible, enabling online brute force and credential stuffing.
- **Remediation applied:** `failed_attempts` and `locked_until` columns (`V28__security_hardening.sql`); five failures lock the account for 15 minutes (`app.security.max-failed-attempts`, `lock-minutes`). Failure state is persisted in a separate transaction so the lock survives the failed request. Login failures are audited.
- **Verification:** Five consecutive wrong-password attempts returned `401`; the sixth attempt returned `423 Locked`. Lock clears automatically after 15 minutes.
- **Residual:** No IP-based throttling, CAPTCHA, or distributed lockout. In a multi-instance deployment, the database lock is shared but login rate is not globally throttled.

V-05 — Missing security headers and permissive CORS risk

- **Severity:** Medium (CVSS 5.4, `AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N`)
- **Affected:** `SecurityConfig.java`
- **Description:** Responses lacked defence-in-depth headers, and a wildcard/over-broad CORS policy would allow hostile origins to call the API from a victim browser.
- **Remediation applied:** HSTS (`max-age=31536000; includeSubDomains`), CSP (`default-src 'none'; frame-ancestors 'none'; base-uri 'none'`), `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`, and `Permissions-Policy` (geolocation/microphone/camera disabled). CORS uses an explicit origin allowlist from `app.cors.allowed-origins`; credentials are disabled.
- **Verification (live):** Headers observed on `401` responses. With `X-Forwarded-Proto: https`, `Strict-Transport-Security: max-age=31536000 ; includeSubDomains` was returned. Allowed origin `http://localhost:5173` received `Access-Control-Allow-Origin`; disallowed origin `https://evil.example` received `403` with no ACAO header.
- **Residual:** The front-end static host must also emit CSP and related headers; the Spring policy applies to API responses.

V-06 — Hardcoded JWT/DB secrets and insecure defaults

- **Severity:** High (CVSS 7.5, `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`)
- **Affected:** `backend/src/main/resources/application.yml`, `backend/.env.example`
- **Description:** The application shipped fallback JWT and database credentials. If deployed without overrides, an attacker with source access could forge tokens or reach the database. The JWT fallback was long enough to sign tokens.
- **Remediation applied:** Runtime values are read from `${JWT_SECRET}`, `${DB_PASSWORD}`, `${DB_URL}`, and `${DB_USERNAME}`. `.env` and `.env.*` are gitignored (`.env.example` is the only tracked template). SMS credentials are server-side environment variables and are never sent to the browser. `SecurityBootstrapCheck` now fails startup when `PRODUCTION=true` and `SEED_PASSWORD=demo123` or the JWT secret is the demo default.
- **Verification:** `git ls-files` contains only `backend/.env.example` (placeholders). No API keys or real secrets are tracked. The production guard is code-inspected; it was not exercised against a production profile in this audit.

- **Residual:** `application.yml` still contains development fallbacks (`cbs_demo_password`, `cbs-general-demo-secret-key-change-me...`); `PRODUCTION=false` is the default. A deployment that forgets `PRODUCTION=true` bypasses the guard. Rotation is manual: changing `JWT_SECRET` invalidates all sessions.

V-07 — Vulnerable front-end dependencies

- **Severity:** High (CVSS 7.3, `AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L`)
- **Affected:** `package.json`, `package-lock.json`
- **Description:** The ProComponents/ProLayout dependency tree carried three high-severity advisories (`@ant-design/pro-components`, `@ant-design/pro-layout`, and `path-to-regexp`). These were used for layout/card UI and were not essential to the application.
- **Remediation applied:** `@ant-design/pro-components` and `@ant-design/pro-layout` were removed; the only used component (`ProCard`, 40 usages) was replaced by a local `.page-shell` wrapper. `npx tsc -b`, the mock-mode build, and `npx vitest run` (50/50) passed after the change.
- **Verification (live):** `npm audit --omit=dev` → `found 0 vulnerabilities` (before: 3 high); `npm ls @ant-design/pro-components @ant-design/pro-layout` → empty; no `ProCard`/pro-components imports remain.
- **Residual:** The backend Maven dependency tree was not scanned with OWASP Dependency-Check. Add it to CI.

V-08 — Mutable audit log with no tamper evidence

- **Severity:** Medium (CVSS 6.5, `AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N`)
- **Affected:** `audit_trail`, `AuditTrailService`, `AuditTrailEventListener`, `V27__audit_trail.sql`, `V28__security_hardening.sql`
- **Description:** Audit records could be updated or deleted by a database user, undermining fraud investigation and regulatory evidence.
- **Remediation applied:** SHA-256 hash chain (`hash = SHA-256(prev_hash + payload)`, genesis `GENESIS`); Hibernate post-insert/update/delete listener captures actor, entity, field, old/new values, IP, and timestamp; sensitive fields are redacted; `forbid_append_only_mutation()` triggers block UPDATE and DELETE on `audit_trail` and `sms_log`. `V29__audit_log_immutable.sql` extends the append-only trigger to the legacy `audit_log`. `/api/audit-trail/verify` recomputes the chain.
- **Verification (live):** `/api/audit-trail/verify` → `{"valid":true,"checked":58}` in `security/evidence/security-test-results.md`; a later re-check returned 64 because the chain grows. PostgreSQL catalog shows `audit_trail_append_only`, `sms_log_append_only`, and `audit_log_append_only`. Direct UPDATE/DELETE on `audit_trail` and `audit_log` raise the append-only exception.
- **Residual:** A database superuser can disable triggers; the hash chain still detects modification unless the attacker rewrites the entire chain. `audit_log` is append-only but not hash-chained, and INSERT is still possible by a DB user (V-19). Export audit records to WORM/SIEM storage for stronger guarantees. Audit list/filter loads all rows into memory, which will not scale indefinitely.

V-09 — MFA implemented but not fully operationalized

- **Severity:** High (CVSS 8.1, `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N`)
- **Status:** Partial
- **Affected:** `AuthService.java`, `SmsService.java`, `SmsController.java`, `app_user`
- **Description:** Before remediation, a stolen or guessed password was sufficient for full access, including administrative functions. SMS MFA now exists, but it is not fully operationalized in production.
- **Remediation applied:** SMS OTP via AfroMessage for ADMIN and MANAGER when `REQUIRE_MFA=true`. OTPs expire in 5 minutes, allow 5 verification attempts, and are throttled (60-second resend, 5 per hour). A successful password check without an OTP returns `202 {"mfaRequired":true}` and sends the code; `/api/auth/login/verify` validates it. Phone and `mfa_enabled` columns were added in V28.
- **Verification:** MANAGER login → `202 {"mfaRequired":true}`; TELLER login → `200` with token (MFA not required for teller). The SMS OTP path was previously validated end-to-end against the AfroMessage gateway.
- **Residual:** Disabled by default (`REQUIRE_MFA=false`); only two roles; no self-service enrolment, reset, or recovery-code process (V-14, Partial); SMS delivery is an external dependency and SIM-swap risk remains.

6.2 Open, Partial, and Residual Findings

> V-19 is marked Fixed (the reported UPDATE/DELETE mutability is closed); its residual non-hash-chained/INSERT risk is described here. V-09 is partially remediated and is covered in §6.1.

V-10 — TLS 1.3 not enforced; mTLS not implemented

- **Severity:** High (CVSS 7.4, `AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N`)

- **Status:** Partial
- **Evidence:** `SecurityConfig` supports HSTS and optional HTTPS redirect (`REQUIRE_HTTPS`). `deploy/nginx-cbs.conf.template` now terminates TLS 1.3 only, redirects HTTP to HTTPS, and adds HSTS/security headers. The template is **not deployed** on the audited host; the local instance serves HTTP. mTLS is absent from the template, `application.yml`, and the SMS client.
- **Impact:** Credentials and bearer tokens can be intercepted on plaintext or weakly negotiated links; service-to-service calls are not mutually authenticated.
- **Remediation update (2026-11-11):** The repository now contains a deployable TLS 1.3 proxy template. Remaining: deploy it with valid certificates, verify with `openssl s_client -tls1_3`, set `REQUIRE_HTTPS=true`, and add mTLS.
- **Remediation:**
  1. Deploy the template (or equivalent ALB policy) with TLS 1.3 only, strong AEAD ciphers, and automated certificate renewal.
  2. Redirect all HTTP to HTTPS; enable `REQUIRE_HTTPS=true`; submit the domain to HSTS preload after validation.
  3. Enforce mTLS for internal service-to-service and any future POS/ERP connector; issue short-lived client certificates.
  4. Add a CI/deployment check using `openssl s_client -tls1_3` and an SSL Labs A+ target.
- **Acceptance:** All external and internal traffic is TLS 1.3; plaintext HTTP is refused; mTLS handshake fails without a valid client certificate.

V-11 — No verified encryption at rest; Fayda ID/phone stored plaintext

- **Severity:** Medium (CVSS 6.1, `AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N`)
- **Status:** Open
- **Evidence:** `V1__baseline.sql` defines `member.fayda_id`, `member.phone`, and `member.email` as plaintext. No TDE, `pgcrypto`, volume-encryption, or KMS configuration is in the repository. Audit redaction covers password/secret/token field names, not Fayda ID or phone. `GET /api/sms/logs` returns full phone numbers to any authenticated reader.
- **Impact:** Database theft, backup leakage, or over-broad DBA access exposes national ID and contact data.
- **Remediation:**
  1. Enable encrypted block volumes and PostgreSQL TDE or storage-level encryption; document key custody and rotation.
  2. Add application-level AES-256-GCM encryption (or tokenization) for Fayda ID and phone; store a blind index for exact-match search; mask in UI, exports, and logs.
  3. Extend audit redaction to `fayda`, `phone`, `email`, and document attachments.
  4. Encrypt backups and test restore.
- **Acceptance:** A raw database dump does not reveal Fayda IDs or phone numbers; keys are held in a KMS/secret manager, not in the repository.

V-12 — No independent penetration test or full OWASP scan

- **Severity:** Medium (assurance gap; CVSS `–`)
- **Status:** Open
- **Evidence:** No third-party test report, scope letter, retest letter, or automated ZAP/Burp report exists. This engagement used code review and targeted API requests.
- **Impact:** Unknown vulnerabilities may remain in less-tested modules, file upload, report exports, and complex loan/accounting workflows.
- **Remediation:** Commission an external CREST/OSCP-qualified team for authenticated multi-role web/API testing before go-live and annually; add OWASP ZAP baseline/full scans and dependency scans to CI; remediate and retest.
- **Acceptance:** Signed penetration-test report with no open Critical/High findings, or accepted risk with compensating controls.

V-13 — No ISO 27001 / ISO 15408 / PCI-DSS certification evidence

- **Severity:** Low / Informational (CVSS `–`)
- **Status:** Open
- **Evidence:** No ISMS scope, risk register, Statement of Applicability, internal audit, Common Criteria Security Target, or PCI attestation. No card data is processed, so PCI-DSS is not applicable to the current scope.
- **Impact:** Cannot demonstrate formal management-system maturity or product assurance to regulators or partners.
- **Remediation:** Establish an ISO 27001 programme (scope, risk assessment, policies, internal audit, management review, certification). Evaluate Common Criteria only if contractually required. Maintain PCI-DSS scope reduction by prohibiting card-data storage.
- **Acceptance:** Certification roadmap approved; ISO 27001 certificate or audit readiness statement; documented PCI scope exclusion.

V-14 — 2FA enrolment, reset, and recovery lifecycle incomplete

- **Severity:** Low (CVSS 3.1, `AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N`)
- **Status:** Partial
- **Evidence:** `AuthService` sends an OTP to the phone already stored on `app_user`; there is no enrolment verification flow, backup factor, recovery-code issuance, or help-desk identity-proofing procedure. If a privileged user has no phone, login returns `403`.
- **Impact:** Users can be locked out; help-desk resets may become a social-engineering path; phone number changes are not strongly verified.
- **Remediation:** Add an enrolment ceremony (password + OTP + confirmation), recovery codes, a signed change-phone workflow with dual control, and audited help-desk resets. Provide a break-glass admin procedure stored offline.
- **Acceptance:** Enrolment, reset, and recovery are documented, tested, and audited; no shared or default second factor.

V-15 — Default demo credentials remain in demo mode

- **Severity:** Critical (CVSS 9.8, `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`) — retained for the residual demo/misconfiguration path
- **Status:** Partial
- **Evidence:** `DataSeeder` now reads `app.security.seed-password` from `SEED_PASSWORD` (default `demo123`) and creates `admin`, `manager`, `teller`, `teller2`, `credit`, `accountant`, and `auditor` when absent. `SecurityBootstrapCheck` fails startup when `PRODUCTION=true` and the seed password is `demo123` or the JWT secret is the demo default. `Login.tsx` now falls back to `demo123` only when `VITE_USE_MOCK=true` or Vite `DEV` mode is active with `VITE_USE_MOCK` not set to `false`; otherwise a blank password is rejected client-side. Local `backend/.env` still has `PRODUCTION=false` and `SEED_PASSWORD=demo123`, so the demo remains usable. **Live test (demo mode):** `POST /api/auth/login` with `{"username":"teller","password":"demo123"}` returned `200` and a valid JWT.
- **Impact:** Production deployments that set `PRODUCTION=true` and a strong `SEED_PASSWORD` reject the known default. A deployment that leaves `PRODUCTION=false`, reuses `demo123`, or keeps an existing database with old `demo123` hashes remains exposed to unauthenticated administrative login. Explicit demo mode is not a production control.
- **Remediation update (2026-11-11):**
  1. Seed password is environment-driven; production startup guard added.
  2. Frontend fallback is now limited to mock/dev demo mode.
- **Remaining remediation:**
  1. Rotate existing `demo123` hashes in any database that predates the change; add a `must_change_password` flag.
  2. Gate `DataSeeder` behind an explicit demo profile as belt-and-braces; do not create demo users in production.
  3. Remove the demo placeholder text from production builds.
  4. Strengthen `SecurityBootstrapCheck`: the current guard rejects `demo123` but not an empty or weak `SEED_PASSWORD`; enforce length/entropy and require `PRODUCTION=true` in deployment manifests.
  5. Add a deployment/CI check that asserts `PRODUCTION=true` and a non-default `SEED_PASSWORD`.
- **Acceptance:** No default credential can authenticate in production; the production profile fails fast on demo secrets; demo mode is isolated from production builds; existing demo hashes are rotated.

V-16 — Coarse authorization; no method-level role checks

- **Severity:** High (CVSS 7.1, `AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:N`)
- **Status:** Partial
- **Evidence:** `SecurityConfig` now adds fine-grained POST rules for `/api/gl-rules/**` (ADMIN/MANAGER/ACCOUNTANT), `/api/compliance/policy` (ADMIN/MANAGER), notification templates/settings (ADMIN/MANAGER), expenses/bank/charges/product-types (ADMIN/MANAGER/ACCOUNTANT), savings product/interest/fees (ADMIN/MANAGER/ACCOUNTANT), loan lifecycle (ADMIN/MANAGER/CREDIT_OFFICER/ACCOUNTANT), shares (ADMIN/MANAGER/ACCOUNTANT), approvals (ADMIN/MANAGER), dormancy (ADMIN/MANAGER), and checkoff (ADMIN/MANAGER/ACCOUNTANT). **Live:** teller `POST /api/gl-rules` → `403`; teller `POST /api/compliance/policy` → `403`; accountant `POST /api/gl-rules` → `400` (authorized, validation failed); accountant `POST /api/compliance/policy` → `403`; teller `POST /api/savings/transactions` → `400` (authorized for teller). **Residual:** there are still **0** `@PreAuthorize` / `@Secured` annotations; PUT/PATCH rules remain broad; `/api/sms/send`, `/api/sms/otp/send`, `/api/accounting/journal`, member import, and some other POST endpoints are not in a fine-grained rule.
- **Impact:** The highest-risk finance/compliance writes are now blocked for tellers, reducing fraud exposure. Remaining broad write paths (PUT/PATCH, SMS, accounting journal) can still be reached by roles that should not have them, so least privilege is not complete.
- **Remediation update (2026-11-11):** Fine-grained POST rules added and verified for the listed modules.
- **Remaining remediation:**
  1. Extend the role-to-endpoint matrix to PUT/PATCH and the remaining POST endpoints (`/api/sms/**`, `/api/accounting/**`, member import, lifecycle approvals).

2. Add `@PreAuthorize("hasAnyRole(...)")` or a centralized authorization service per controller method.
3. Add negative authorization tests for every write endpoint and every role.

- **Acceptance:** Every write endpoint returns `403` for roles outside its allowlist; tests cover the full role × endpoint matrix; no broad non-AUDITOR write fallback remains.

V-17 — Systematic input validation incomplete

- **Severity:** Medium (CVSS 5.3, `AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L`)
- **Status:** Open
- **Evidence:** Negative savings amount → `400` (`SavingsService.transact`); SQL-injection login → `401`; JPA repositories parameterize queries. However, `spring-boot-starter-validation` is present but unused: **0** `@Valid` annotations and **107** `Map<String,Object>` request-body parameters. Many controllers parse maps manually and cast values.
- **Impact:** Inconsistent validation can cause `500` errors, type-confusion, partial writes, and injection or business-logic bypass in less-tested endpoints.
- **Remediation:** Replace map-based bodies with typed DTOs and Bean Validation (`@NotNull`, `@Positive`, `@Size`, `@Pattern`); add a global `MethodArgumentNotValidException` handler; enforce enum allow-lists; add property-based/fuzz tests for financial endpoints.
- **Acceptance:** All write endpoints use validated DTOs; invalid input returns a consistent `400` with no stack trace; fuzz tests show no `5xx`.

V-18 — JWT stored in browser `localStorage`

- **Severity:** Medium (CVSS 5.4, `AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N`)
- **Status:** Open
- **Evidence:** `src/context/AuthContext.tsx` stores the token in `localStorage` (`cbs-token`); `src/api/client.ts` reads it and sends it as a Bearer header. A successful XSS anywhere in the front end can exfiltrate the token.
- **Impact:** Session hijacking for up to 30 minutes; no server-side revocation list.
- **Remediation:** Prefer `HttpOnly; Secure; SameSite=Strict` cookies with CSRF protection, or keep tokens in memory with refresh rotation. Add a strict CSP to the static front-end host, sanitize rendered HTML, and add a logout/revocation mechanism (token version or deny-list).
- **Acceptance:** JavaScript cannot read the session credential; CSP blocks inline/untrusted scripts; logout invalidates the session server-side.

V-19 — Legacy `audit_log` mutability

- **Severity:** Medium (CVSS 4.9, `AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N`)
- **Status:** Fixed (residual: no hash chain; INSERT still possible)
- **Evidence:** `V1__baseline.sql` creates `audit_log` (id, username, action, entity, entity_id, detail, occurred_at). `AuditService.record` inserts approval events into it, and `/api/audit/logs` reads it. `V29__audit_log_immutable.sql` adds the `audit_log_append_only` trigger. **Live:** catalog shows `audit_log_append_only`; `INSERT` succeeds; `UPDATE` and `DELETE` fail with `ERROR: This table is append-only and cannot be modified or deleted`.
- **Impact before fix:** Approval audit evidence could be altered or deleted by a database user, and auditors could rely on a mutable legacy log.
- **Remediation applied:** Append-only trigger on `audit_log`, matching `audit_trail` and `sms_log`.
- **Residual:** `audit_log` is append-only but not hash-chained; a DB user can still INSERT false entries, and the table can diverge from `audit_trail`. The hash-chained `audit_trail` remains the stronger source. Retire `audit_log` or migrate `AuditService.record` to `AuditTrailService.append` and add reconciliation.
- **Acceptance:** UPDATE/DELETE are rejected (met). Longer term: one authoritative, hash-chained audit source.

---

7. Test Evidence

> Results marked **audit run** were recorded during the authenticated test phase. Results marked **live** were re-verified on 10–11 November 2026. Lockout and MFA tests were not repeated to avoid account lockout and live SMS side effects. `checked:58` is the audit-trail length in `security/evidence/security-test-results.md`; a later re-check returned 64 because the chain grows.

#	Test	Request	Expected	Observed	Result
1	Unauthenticated member list	`GET /api/members`	401	`401`	PASS
2	Unauthenticated system health	`GET /api/system/health`	401	`401`	PASS
3	Login with no password	`POST /api/auth/login` `{"username":"admin"}`	401	`401`	PASS (audit run)
4	Login with wrong password	`POST /api/auth/login` `{"username":"teller","password":"wrong"}`	401	`401`	PASS (audit run)
5	Account lockout	5× wrong password, then 6th attempt	5×401 then 423	`401` ×5, then `423`	PASS (audit run)
6	MFA challenge for MANAGER	`POST /api/auth/login` with correct password, `REQUIRE_MFA=true`	202 `mfaRequired`	`202 {"mfaRequired":true}`	PASS (audit run)
7	MFA not required for TELLER	`POST /api/auth/login` with correct password	200 token	`200` + token	PASS
8	TELLER user directory	`GET /api/auth/users` as TELLER	403	`403`	PASS
9	MANAGER user directory	`GET /api/auth/users` as MANAGER	403	`403`	PASS (audit run)
10	ADMIN user directory	`GET /api/auth/users` as ADMIN	200	`200`	PASS (audit run)
11	TELLER member read	`GET /api/members` as TELLER	200	`200`	PASS
12	TELLER audit read denied	`GET /api/audit-trail` as TELLER	403	`403`	PASS
13	TELLER system area denied	`GET /api/system/backups` as TELLER	403	`403`	PASS
14	AUDITOR audit read	`GET /api/audit-trail` as AUDITOR	200	`200`	PASS
15	AUDITOR write denied	`POST /api/members` as AUDITOR	403	`403`	PASS
16	AUDITOR delete denied	`DELETE /api/members/1` as AUDITOR	403	`403`	PASS
17	TELLER member write allowed	`POST /api/members` with `{}` as TELLER	400 validation	`400`	PASS (authorization allowed)
18	TELLER finance write	`POST /api/gl-rules` with `{}` as TELLER	403	`403`	PASS (V-16 partial fix)
19	TELLER compliance write	`POST /api/compliance/policy` with `{}` as TELLER	403	`403`	PASS (V-16 partial fix)
19a	ACCOUNTANT finance write	`POST /api/gl-rules` with `{}` as ACCOUNTANT	400 (allowed validation)	`400`	PASS (expected role access)
19b	ACCOUNTANT compliance write	`POST /api/compliance/policy` with `{}` as ACCOUNTANT	403	`403`	PASS (V-16 partial fix)
20	Negative amount	`POST /api/savings/transactions` `amount:-500`	400	`400 "Amount must be a positive number"`	PASS
21	SQL injection in login	username `' OR 1=1--`	401	`401 "Invalid username or password"`	PASS
22	Audit chain integrity	`GET /api/audit-trail/verify`	valid	`{"valid":true,"checked":58}`	PASS

#	Test	Request	Expected	Observed	Result
23	Audit/SMS append-only triggers	PostgreSQL catalog query	triggers present	`audit_trail_append_only`, `sms_log_append_only`, `audit_log_append_only`	PASS
24	Security headers	`GET /api/system/health`	headers present	CSP, XFO DENY, XCTO nosniff, Referrer no-referrer, Permissions-Policy	PASS
25	HSTS on secure request	same + `X-Forwarded-Proto: https`	HSTS	`max-age=31536000 ; includeSubDomains`	PASS
26	CORS allowed origin	`OPTIONS /api/members` Origin `http://localhost:5173`	200 + ACAO	`200`, `ACAO: http://localhost:5173`	PASS
27	CORS disallowed origin	`GET /api/members` Origin `https://evil.example`	no ACAO	`403`, no ACAO	PASS
28	JWT lifetime	decode issued token	1800 s	`ttl_seconds=1800`	PASS
29	Password policy	create user with `"abc"`	400	`400`	PASS (audit run)
30	Front-end dependency scan	`npm audit --omit=dev`	0	before: 3 high; after: `found 0 vulnerabilities`	PASS (V-07 Fixed)
31	Error handling	invalid requests	no stack trace	generic JSON error, `include-stacktrace: never`	PASS
32	TLS 1.3 / mTLS	external TLS handshake	TLS 1.3 / mTLS	nginx TLS 1.3 template provided; not deployed; no mTLS	**PARTIAL (V-10)**
33	Encryption at rest	raw DB/backup inspection	ciphertext	plaintext Fayda/phone in schema	**FAIL (V-11)**
34	Independent pen test	report/scope letter	report	none	**NOT PERFORMED (V-12)**
35	Default demo credential	`POST /api/auth/login` `{"username":"teller","password":"demo123"}`	401 in production; demo mode may allow	`200` + JWT in demo/dev; production guard rejects default at startup	**PARTIAL (V-15)**
36	Legacy audit log mutability	`UPDATE` / `DELETE audit_log` via psql	rejected	append-only error; `audit_log_append_only` present	PASS (V-19 Fixed)
37	Production guard	start with `PRODUCTION=true`, `SEED_PASSWORD=demo123`	startup fails	code-inspected guard; not exercised against a production profile	**NOT TESTED (V-15 residual)**
38	Build and unit tests	`npx tsc -b` ; `VITE_USE_MOCK=true npm run build` ; `npx vitest run`	clean	tsc clean; build success; 50/50 tests	PASS
39	Backend compile	`mvn -o -Dmaven.test.skip=true compile`	clean	clean	PASS

8. Remediation Roadmap

P0 — Immediate (0–7 days)

1. Verify `PRODUCTION=true` and a strong `SEED_PASSWORD` / `JWT_SECRET` in the target deployment; rotate any existing `demo123` hashes and force a password change (V-15).
2. Gate `DataSeeder` behind an explicit demo profile; remove the demo password placeholder from production builds (V-15).
3. Deploy the nginx TLS 1.3 template with valid certificates, set `REQUIRE_HTTPS=true`, and verify HSTS/TLS with `openssl s_client` (V-10).
4. Extend fine-grained authorization to PUT/PATCH, `/api/sms/**`, `/api/accounting/**`, member import, and remaining lifecycle writes; add negative tests (V-16).

5. Update `scripts/api-smoke.sh` and the integration-test login helpers to the password contract (O-01).

P1 — Short term (7–30 days)

1. Enable volume/TDE encryption and implement AES-GCM field encryption for Fayda ID/phone; mask exports (V-11).
2. Replace map-based request bodies with validated DTOs on financial and administrative endpoints (V-17).
3. Move JWT to `HttpOnly; Secure; SameSite` cookies or in-memory storage with refresh rotation (V-18).
4. Add OWASP ZAP baseline/full scans and Maven Dependency-Check to CI (V-07, V-12).
5. Retire `audit_log` or migrate `AuditService.record` to the hash-chained `audit_trail`; add reconciliation (V-19 residual).

P2 — Medium term (30–90 days)

1. Commission an independent penetration test and retest after fixes (V-12).
2. Implement 2FA enrolment, recovery codes, and audited help-desk reset (V-14).
3. Define retention/deletion policy and implement purge/anonymization (compliance 5.2).
4. Implement mTLS for service-to-service and any POS connector (V-10).
5. Harden DB least privilege: separate migration/runtime users, non-root service account, encrypted backups (10.2).

P3 — Long term (90–180 days)

1. ISO/IEC 27001 ISMS implementation and certification (V-13).
2. Evaluate ISO/IEC 15408 only if contractually required (V-13).
3. Annual penetration test and continuous dependency/container scanning.
4. SIEM ingestion of audit events, alerting on `verify` failures and trigger errors, and WORM audit export.

---

9. Limitations and Attestation

- No production infrastructure, TLS terminator, database encryption, backup system, or cloud console was available. Statements about those controls are therefore **not verified**.
- The nginx TLS 1.3 template was code-reviewed but **not deployed** on the audited host; no external TLS handshake, certificate chain, or mTLS test was performed.
- The production credential guard was code-reviewed but not exercised against a `PRODUCTION=true` profile. Demo mode still uses `demo123`; existing databases with old hashes were not inspected for rotation.
- No POS, invoice machine, card reader, firmware, or physical device was in scope; device compliance is **not claimed**.
- No independent penetration test, ISO 27001 audit, Common Criteria evaluation, PCI-DSS assessment, or fiscal-authority certification was performed.
- CVSS scores are estimates. Actual risk depends on deployment, data sensitivity, and threat model.
- The legacy integration tests and smoke script do not reflect the remediated auth contract and were not used as pass evidence.
- Test data was local/demo data. No production personal data was accessed.

Attestation: This report is an accurate record of the controls inspected and the tests performed. Controls that were not present or not evidenced are marked Partial, Gap, Open, or Not Applicable. No compliance or certification is claimed beyond the evidence cited.

---

10. Additional Observations (Non-Finding)

ID	Observation	Recommendation
O-01	Legacy passwordless login remains in `scripts/api-smoke.sh`, `BaseApiIT`, `SaccoApiIntegrationTest`, `ApiContractIT`, `PerformanceIT`, and `EdgeCasesIT`. These tests will fail against the remediated backend and cannot be used as release evidence.	Update all helpers to send a real password or a test-only token fixture; add security regression tests for 401/423/403.
O-02	`Login.tsx` contains a demo email-2FA path (`/api/auth/2fa/start`, `/api/auth/2fa/verify`, `/api/auth/2fa/resend`) that exists only in MSW mocks, not in the Spring backend.	Remove the demo path or implement a real email factor; avoid misleading users about available MFA.
O-03	`AuthContext.switchRole` posts only `{role}` to `/api/auth/login`; after password enforcement this role-switch action will return `401`.	Require re-authentication with the target account's password, or remove the role-switch shortcut.

ID	Observation	Recommendation
O-04	SMS rate limiting is in-memory per application instance.	Use Redis or a shared store for multi-instance deployments; add per-IP and per-account limits at the edge.
O-05	Audit list/filter loads all entries into memory and scans them.	Add indexed queries and pagination before audit volume grows.
O-06	`GET /api/sms/logs` returns full recipient phone numbers to any authenticated reader; there is no role restriction or masking.	Restrict SMS logs to ADMIN/MANAGER/AUDITOR and mask all but the last four digits.

End of report.